



Zero Trust - Navigating Conditional Access

Manish Periwal
Oslo, Norway



About Me

Manish Periwal

Senior Security Engineer

Norges Bank Investment Management

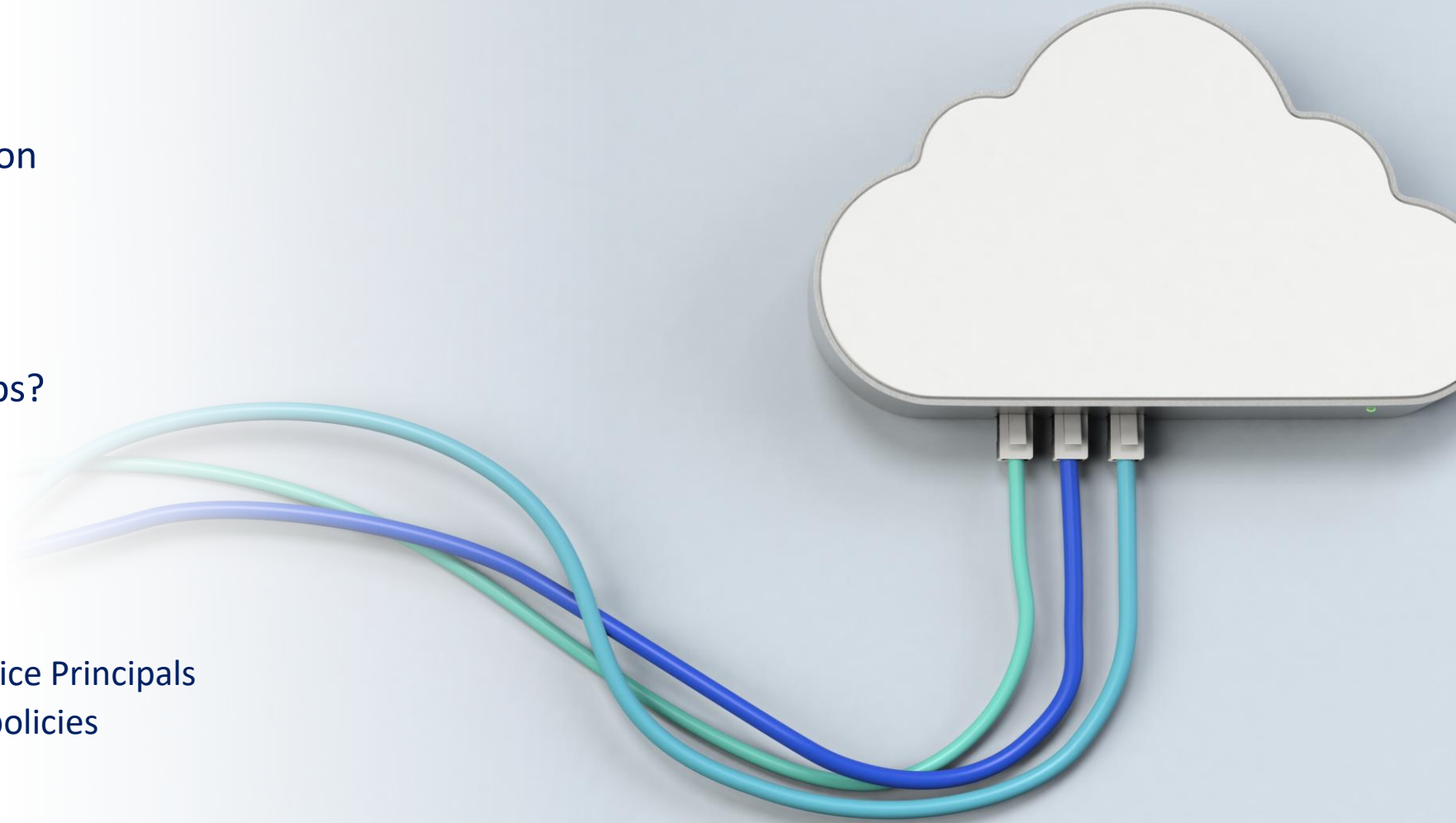
- ✓ Over a decade of experience in IT. Have worked with multiple clients – Apple , Sony Pictures, DNB, and others!
- ✓ Experience in Application Security, Cloud Security, DevSecOps, Penetration Testing.
- ✓ Currently focussed on Identity Security, Identity Governance & Administration

Completing 7 years in Norway this week!



Agenda

- ✓ Phishing Resistant Authentication
 - Why Strong authentication
 - Benefits & Efficient Rollout
- ✓ Do you have control over Groups?
 - Power over Groups
 - Are you aware of the changes
- ✓ Workload Identity Protection
 - Protecting Applications & Service Principals
 - Risk based or Location based policies





Phishing Resistant Authentication

Why Strong Authentication?

Microsoft Entra data shows password-based attacks make up over 99% of the 600 million daily identity attacks

- ✓ No More Password Nightmares
- ✓ Superhero Level Security
- ✓ Time Saver Extraordinaire
- ✓ FIDO, Passkeys or Windows Hello



How to & Best Practices

- ✓ Authentication Methods
- ✓ Conditional Access Policies
- ✓ Policy as Code [using Terraform]
- ✓ Report Only mode and analyze impact
- ✓ Rollout Plan – In phases
- ✓ Communication is the Key



Corner Cases

- ✓ What is my Authentication does not work?
- ✓ App Exclusions





Do you have control over Groups?

Do you have control over Groups?

Group Administrator, Group Owners or any Identity (User or Service principal) with **Group.Write** permissions are as strong as **Global Admins**.

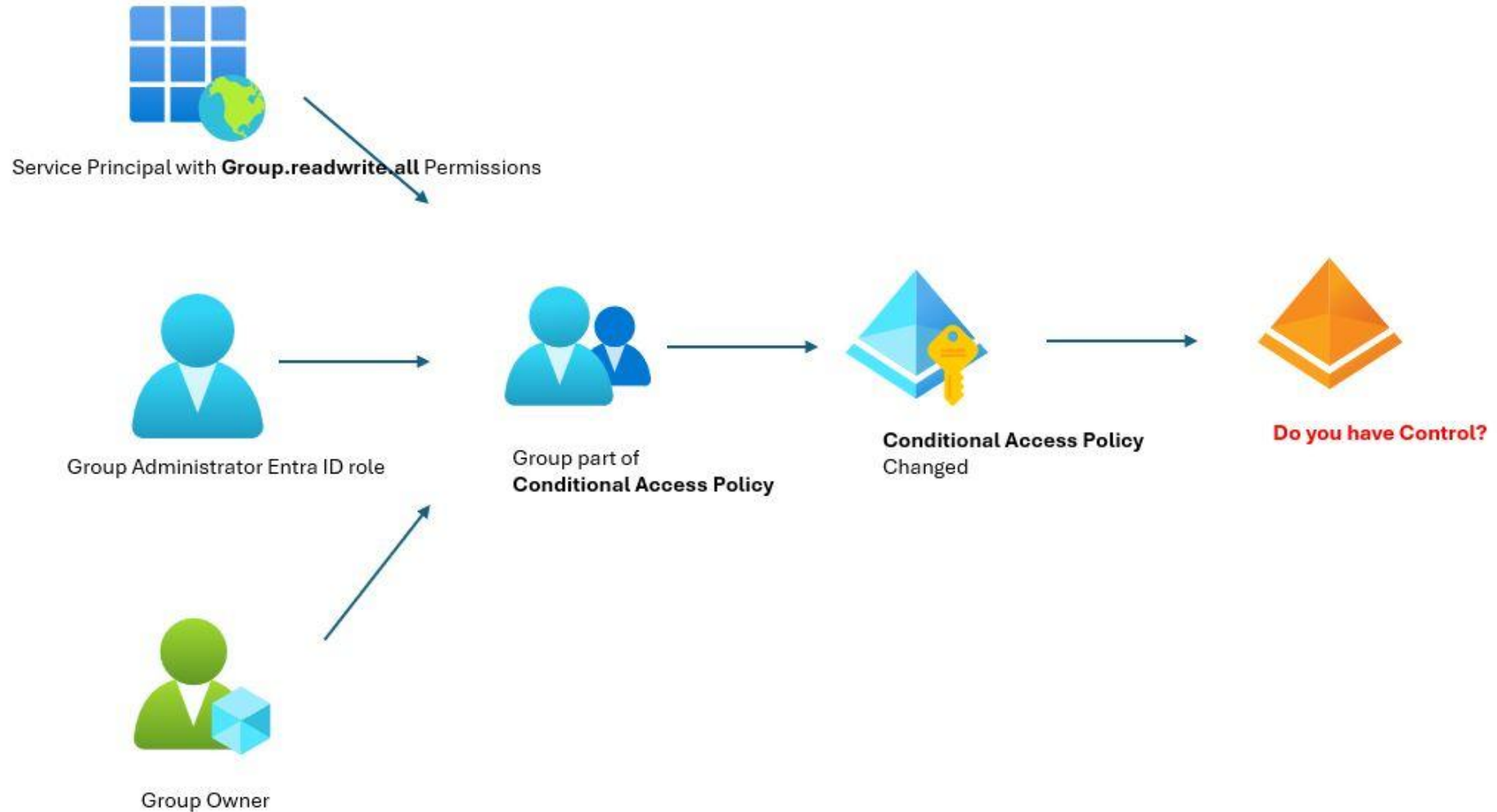
Major Impact on **Conditional Access Policies** and **Enterprise Application** assignments.

Conditional Access Policy Changes – **Alerts**.

But have you got the Groups covered as well?



Do you have control over Groups?



Monitor your Groups

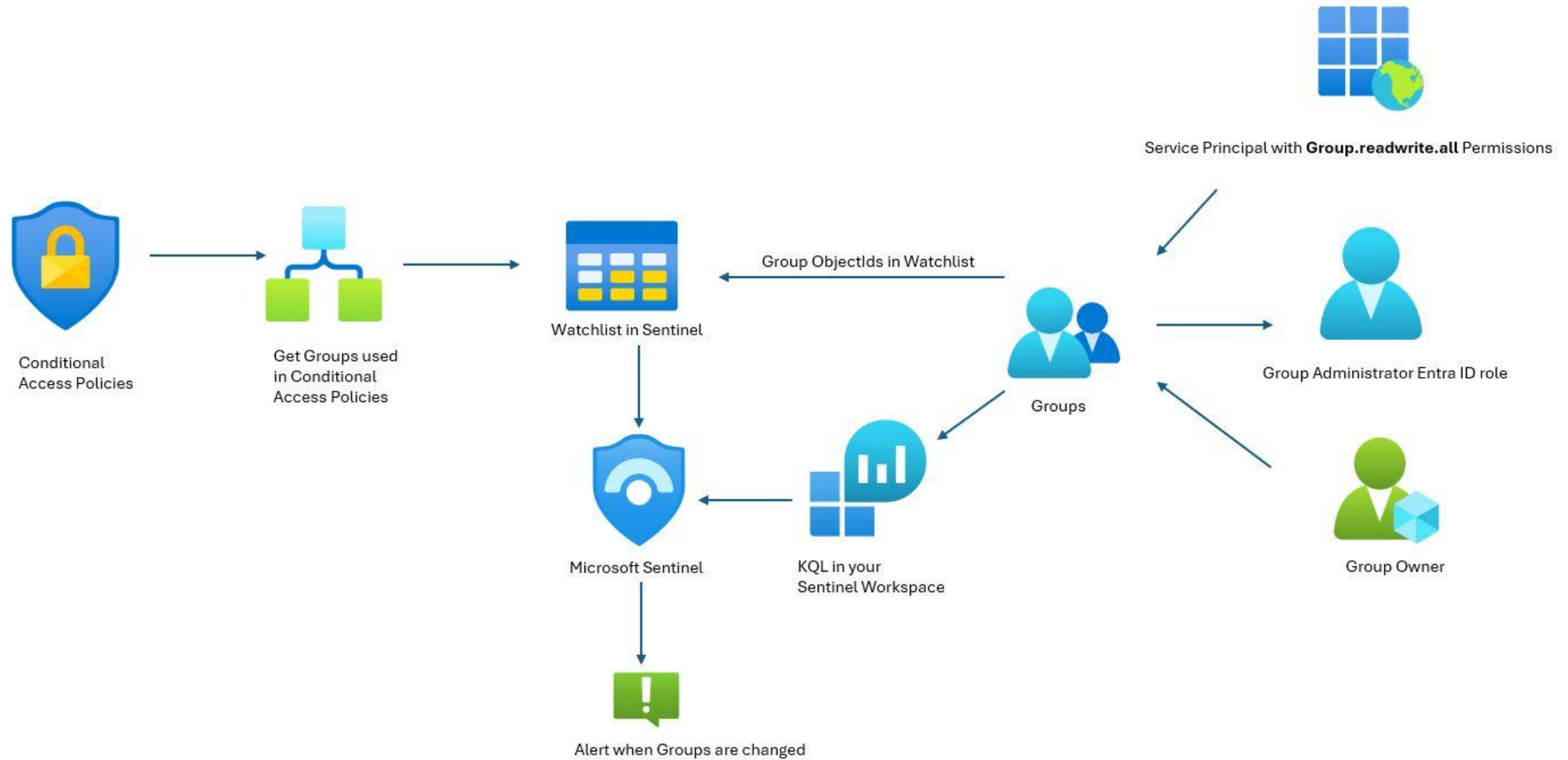
Alert on Group changes using Microsoft Sentinel

Break glass account – never in Groups

Restricted Management Administrative Units



Monitor your Groups!



KQL Example

AuditLogs

```
| where TimeGenerated > ago(1d) // Adjust time range as needed  
| where OperationName in ("Add member to group", "Remove member from group", "Add owner to group")  
| extend GroupDisplayName =  
iff(isnotempty(parse_json(tostring(parse_json(tostring(TargetResources[0].modifiedProperties))[1].newValue))), parse_json(tostring(parse_json(tostring(TargetResources[0].modifiedProperties))[1].newValue)),  
parse_json(tostring(parse_json(tostring(TargetResources[0].modifiedProperties))[1].oldValue)))  
| extend GroupObjectId =  
iff(isnotempty(parse_json(tostring(parse_json(tostring(TargetResources[0].modifiedProperties))[0].newValue))), parse_json(tostring(parse_json(tostring(TargetResources[0].modifiedProperties))[0].newValue)),  
parse_json(tostring(parse_json(tostring(TargetResources[0].modifiedProperties))[0].oldValue)))  
| where GroupObjectId in (_GetWatchlist('conditionalaccessgroups'))  
| project groupguids)  
| project TimeGenerated,GroupDisplayName,GroupObjectId,OperationName,Identity
```

Monitor your Groups!

Microsoft Sentinel | Incidents

Selected workspace

Search

Create incident (Preview) Refresh Last 24 hours Actions Delete Security efficiency workbook Columns Guides & Feedback

General

Overview (Preview) Logs News & guides Search

Threat management

Incidents

Workbooks Hunting Notebooks Entity behavior Threat intelligence MITRE ATT&CK (Preview) SOC optimization

Content management

Content hub Repositories (Preview) Community

Configuration

Workspace manager (Preview) Data connectors Analytics Summary rules (Preview) Watchlist Automation

5 Open incidents 3 New incidents 2 Active incidents

Open incidents by severity

High (1) Medium (0) Low (1) Informational (3)

Search by ID, title, tags, owner or product

Severity: All Status: 2 selected Incident Provider name: All Alert product name: All Owner: All

Auto-refresh incidents

Severity	Incident number	Title	Alerts	Incident provider na...	Alert product name	Created time	Last update time
Informational	11492	[IAM] Conditional Access ...	1	Microsoft Defender ...	Microsoft Sentinel	12/23/24, 10:27 AM	12/23/24, 10:27 A

[IAM] Conditional Access Group changed

Incident number 11492

Investigate in Microsoft Defender XDR

Unassigned New Informational

Owner Status Severity

Entities (0)

Incident workbook Incident Overview

Analytics rule [IAM] Conditional Access Group changed

Tags

Incident link https://portal.azure.com/#asset/Microsoft_Azure_Security_Inshigh...

Last comment (Total: 0)

Write a comment

GroupName POL (less)

Time 2024-12-22T23:16:07.898715Z

OperationName Remove member from group



Workload Identity Protection

Protect your Applications

Conditional Access for Users, **but what about Applications?**

How do you protect applications or constraint over-privileged applications?

Workload Identity Protection –
Standalone per app license in Entra ID



Protect your Applications

- ✓ Custom Security Attributes
- ✓ Apply Attributes to Apps - Automation
- ✓ Conditional Access Policies



Protect your Applications

Microsoft Entra admin center

Search resources, services, and docs (G+)

Copilot

2

?

?

c1-mpw@nbimdevEntra...

ENTRA ID POC

Home

What's new

Diagnose & solve problems

Favorites

Identity

Overview

Users

Groups

Devices

Applications

Home > Custom attributes > groupWriteApp | Active attributes > Enterprise a

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Control access based on who the policy apply to, such as users and group identities, directory roles, or external identities. [Learn more](#)

Name *

CAP - Application Group Write Policy

What does this policy apply to?

Workload identities

Include Exclude

None

All owned service principals

Select service principals

Assignments

Users or workload identities

Specific service principals included

Target resources

No target resources selected

Network

NEW

Edit filter

Configured

Edit filter

Configure

Yes No

Using custom security attributes you can use the rule builder or rule syntax text box to create or edit the filter rules. In the preview, only attributes of type String are supported. Attributes of type Integer or Boolean will not be shown. [Learn more](#)

And/Or	Attribute	Operator	Value
	groupWriteApp_groupWrite1	Equals	TRUE

+ Add expression

Rule syntax

CustomSecurityAttribute.groupWriteApp_groupWrite1 -eq "TRUE"

Edit

Protect your Applications

Microsoft Entra admin center

Search resources, services, and docs (G+)

Home

What's new

Diagnose & solve problems

Favorites

Identity

Overview

Users

Groups

Devices

Applications

Enterprise applications

App registrations

Protection

Identity Protection

Conditional Access

Authentication methods

Password reset

Home > Custom attributes > groupWriteApp | Active attributes > Enterprise applications | All

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Control user access based on their network or physical location. [Learn more](#)

Name *

CAP - Application Group Write Policy

Assignments

Users or workload identities

Specific service principals included

Target resources

All resources (formerly 'All cloud apps')

Network **NEW**

Any network or location and all trusted locations excluded

Conditions

1 condition selected

Access controls

Grant

Block access

Session

Configure

Yes No

Include Exclude

Select the locations to exempt from the policy

☒ All trusted networks and locations

☐ All Compliant Network locations

☐ Selected networks and locations

To create a Conditional Access policy ensuring your tenant's members are coming from their compliant network, make sure Global Secure Access (GSA) is deployed and Adaptive Access Signaling in GSA is enabled in your tenant. [Learn more on how to enable GSA Adaptive Access Signaling.](#)

'Locations' condition is moving! Locations will become the 'Network' assignment with a new Global Secure Access capability of 'All Compliant network locations'. No action required. [Learn more](#)

19

Thankyou!

